EK-1.2. İşlevsel Olmayan İsterler

İşlevsel olmayan isterler, uygulamanın güvenlik, veri bütünlüğü, dayanıklılık, performans, kullanılabilirlik, uyumluluk, kurulum ve işletim özelliklerini tanımlamaktadır.

Çizelge EK-1.2. Aptora uygulamasının işlevsel olmayan isterleri

Kod	İster
İOG-01	Aptora'nın üretim sürümü Windows tabanlı bir sunucu üzerinde çalışabilecek ve tek kurulum paketi üzerinden dağıtılabilecek biçimde hazırlanmalıdır.
İOG-02	Üretim kurulum paketi uygulamanın ihtiyaç duyduğu Node.js çalışma zamanını ve gerekli üretim bağımlılıklarını içermeli; hedef sunucuda ayrıca Node.js, npm, Git veya ayrı bir veri tabanı sunucusunun kurulmasını gerektirmemelidir.
İOG-03	Geliştirme ve üretim paketi oluşturma ortamında Node.js 20.17 veya daha yeni bir sürüm kullanılmalıdır.
İOG-04	Uygulama verileri yerel SQLite veri tabanında kalıcı olarak saklanmalı ve ilişkisel bütünlük yabancı anahtarlar ile uygun veri tabanı kısıtları kullanılarak korunmalıdır.
İOG-05	Birbiriyle ilişkili birden fazla veri tabanı değişikliğinin birlikte gerçekleştirilmesi gereken işlemlerde transaction mekanizması kullanılmalı ve hata durumunda kısmi güncelleme oluşması engellenmelidir.
İOG-06	Yönetici ve aday hesapları birbirinden bağımsız kimlik doğrulama ve oturum mekanizmalarıyla yönetilmeli ve aday hesaplarına yönetim yetkileri verilmemelidir.
İOG-07	Yönetici ve aday parolaları geri döndürülebilir biçimde saklanmamalı, kimlik doğrulamada güvenli parola özetleme yöntemi kullanılmalıdır.

Sonraki sayfada devam etmektedir.

Çizelge EK-1.2'in devamı

Kod	İster
İOG-08	TOTP anahtarları, SMTP parolaları ve geri alınması gereken diğer hassas yapılandırma değerleri açık metin olarak saklanmamalı ve uygulama düzeyinde kimliği doğrulanmış şifreleme ile korunmalıdır.
İOG-09	JWT imzalama anahtarı ve veri şifreleme anahtarı kaynak kodundan bağımsız yapılandırılmalı; üretim ortamında geçerli ve yeterli uzunlukta anahtarlar bulunmadığında uygulama çalışmayı reddetmelidir.
İOG-10	Yönetici ve aday web oturumları istemci tarafındaki JavaScript tarafından okunamayan `HttpOnly` çerezler üzerinden yürütülmeli ve çerezlerde `SameSite=Strict` politikası uygulanmalıdır.
İOG-11	HTTPS kullanılan dağıtımlarda kimlik doğrulama çerezleri `Secure` niteliği ile sınırlandırılmalıdır.
İOG-12	Farklı kaynaklardan gelen web istekleri yalnızca açıkça izin verilen kaynaklardan kabul edilmeli ve çapraz kaynak erişiminde CORS politikası uygulanmalıdır.
İOG-13	Web yanıtlarında içerik güvenlik politikası, çerçeveleme engeli, içerik türü koruması ve referrer politikası gibi temel tarayıcı güvenlik başlıkları kullanılmalıdır.
İOG-14	Kimlik doğrulama uç noktalarına ve aday oturumlarına gönderilebilecek isteklerin sayısı sınırlandırılarak kaba kuvvet ve aşırı istek davranışlarının etkisi azaltılmalıdır.
İOG-15	İstemciden alınan kullanıcı girdileri sunucu tarafında doğrulanmalı; soru, sınav, oturum ve cevap verilerinde tanımlanan sınırlar dışında kalan değerler kabul edilmemelidir.
İOG-16	HTTP istek gövdelerinin boyutu sınırlandırılarak gereksiz kaynak tüketimine yol açabilecek aşırı büyük istekler engellenmelidir.

Sonraki sayfada devam etmektedir.

Çizelge EK-1.2'in devamı

Kod	İster
İOG-17	Üretim ortamında istemciye gereksiz dahili hata ayrıntıları, gizli anahtarlar, kimlik doğrulama çerezleri veya aday parolaları aktarılmamalı ve bu bilgiler uygulama loglarına açık biçimde yazılmamalıdır.
İOG-18	Güvenlikle ilişkili yönetici işlemleri kalıcı denetim kayıtlarıyla izlenebilmeli ve bu kayıtların saklama süresi yapılandırılabilir olmalıdır.
İOG-19	Sınav başladığında ilgili sınavın soru ve yapılandırma bilgileri oturuma bağlı olarak korunmalı; sınav tanımında daha sonra yapılan değişiklikler aktif veya tamamlanmış sınavların bütünlüğünü bozmamalıdır.
İOG-20	Aday tarafından gönderilen cevaplar yalnızca ilgili sınav oturumunda bulunan soru ve cevap seçenekleriyle eşleştiğinde kabul edilmelidir.
İOG-21	Süresi dolmuş aktif değerlendirme oturumları istemci davranışına bağlı olmadan sunucu tarafında tespit edilip sonuçlandırılabilmelidir.
İOG-22	SMTP bağlantılarında sunucu sertifikasının doğrulanması etkin olmalı ve SMTP parolaları uygulama içinde şifrelenmiş olarak saklanmalıdır.
İOG-23	Doğrudan HTTP ile gerçekleştirilen üretim dağıtımı yalnızca güvenilir yerel ağ, belirli kaynak adresleri veya VPN gibi kontrollü ortamlarda kullanılmalı; güvenilmeyen veya genel ağlarda HTTPS kullanılmalıdır.
İOG-24	Windows üzerinde uygulama sistem açılışında otomatik olarak başlatılabilmeli ve beklenmeyen süreç hatalarında kontrollü yeniden başlatma politikası uygulanabilmelidir.
İOG-25	Sunucu sürecine yapay bir azami çalışma süresi uygulanmamalı; uygulama yönetimsel olarak durdurulana veya bir hata oluşana kadar çalışmaya devam edebilmelidir.
İOG-26	Uygulamanın kurulması, başlatılması, durdurulması, yeniden başlatılması, loglarının görüntülenmesi ve temel yönetim işlemlerinin gerçekleştirilmesi için Windows üzerinde ayrı bir yönetim mekanizması sağlanmalıdır.